

欧洲法规全景矩阵

法规 / 标准	类型	监管维度	适用锐明产品	强制程度	关键截止日期
GDPR	EU 法规	个人数据采集、存储、传输、处理的全生命周期隐私保护据隐私	全系（摄像头、云平台）	★★★ 法律强制	已生效
CRA	EU 法规	所有含数字元素产品（硬件+软件）的全生命周期网络安全	全系联网设备	★★★ 法律强制	完整执行： 2027.12.11
EU AI Act	EU 法规	人工智能系统的风险分级、合规要求、透明度和人工监督	ADAS、DMS、客流分类	★★★ 法律强制	高风险： 2027.08.02
NIS2	EU 指令	网络安全（运营商侧）；NIS2主要约束使用锐明产品的欧洲公交运营商。但锐明作为关键系统供应商，同样受到NIS2供应链安全条款的间接约束	云平台 /SaaS 运营	★★★ 法律强制	已生效（2024.10）
RED / 2014/53/EU	EU 指令	无线设备安全	所有无线通信设备	★★★ 法律强制	已认证
GSR / 2019/2144	EU 法规	锐明的DMS和CMCS须满足GSR对应的UN Regulation性能指，车辆制造商在型式认证时会要求供应商提供符合性证明。锐明作为Tier-1供应商，须提供产品符合相关UN法规的测试报告。	ADAS、DMS、CMCS	★★★ 法律强制	ADDW： 2026.07.07
CE Marking	EU 框架	市场准入	全部硬件产品	★★★ 法律强制	持续要求
ITxPT	行业标准	车载互联互通	IBCU、车载网络	★★ 采购要求	已广泛执行
VDV 301 / IBIS-IP	德国标准	车内通信协议	IBCU、信息显示	★★ 德语区要求	已广泛执行

GDPR 背景 · 角色定位 · 涉及数据类型

我们在 GDPR 中的角色

✔️ **✅ 数据处理者 (Processor) — 主要定位**

锐明提供设备和云平台，按欧洲公交运营商（控制者）的指令处理数据。须与每位欧洲客户签署 DPA（Article 28）。

📄 **数据控制者 (Controller)**

欧洲公交运营商 — 决定数据处理目的和方式

⊗ **🔴 高风险：锐明升格为控制者的场景**

- 用欧洲客户视频训练 AI 算法（未获运营商授权）
- 汇聚多运营商数据做横向分析生成报告或出售
- 中国团队随时访问欧洲客户实时 / 历史视频

正确做法：在DPA附件中加入书面授权，写清楚：数据类型、处理目的、脱敏要求、使用范围。有了这个授权，锐明仍是处理者，而非控制者

锐明产品涉及的个人数据类型

产品 / 系统	数据类型	保护等级
车载 DVR/MDVR	乘客 & 驾驶员影像	Article 6 普通
DMS 驾驶员监控	面部图像、眼动、头部姿态	⚠️ Article 9 特殊
ADAS 前向摄像	行人面部、车牌	Article 6 普通
ANPR 执法摄像	车牌（可关联个人）	Article 6 普通
客流 OD 系统	上下车地点 / 时间	聚合统计不适用
运营调度云平台	驾驶员位置、账号	Article 6 普通

六大基本原则 · 对锐明产品的具体要求

01 合法、公平、透明

- 车内张贴摄像头告知标识
- 驾驶员须在入职时被告知 DMS 系统存在
- 运营商须在隐私政策中披露锐明系统及数据传输路径

⚠ 锐明未告知运营商的操作 → 运营商违规 → 依合同追责锐明

02 目的限制

- 行车安全录像不得用于商业广告分析
 - DMS 疲劳数据不得用于绩效排名 / 薪资扣罚
 - ANPR 录像不得用于追踪个人行动轨迹
- 云平台须实现数据隔离，不同目的数据不得混用

03 数据最小化

- 客流计数系统输出统计数字，不上传原始人脸影像
- DMS 仅需输出【疲劳 / 正常】结果，无需存储面部原始图像（适当加密或匿名化）
- 遥测数据只采集运营调度所需最小粒度

04 存储限制（保留期限）

- 普通录像：7-30 天，超期自动覆写
 - 触发事件录像（事故 / 急刹）：3-6 个月
 - DMS 行为数据：30-90 天
- 设备和平台须实现自动定期删除机制

05 完整性与保密性

- 视频传输全程 TLS 1 加密
- 云平台角色权限管理（RBAC）
- 数据泄露 72 小时内报告（Article 33）

→ 欧洲数据中心存储加密

06 问责制

- 建立处理活动记录（ROPA，Article 30）
 - 留存合规证明文件（DPA、LIA）
 - 发生问题时须证明自己已履行合规义务
- 【说你做了】必须有文档证明

DMS 特殊类别数据风险 · 车内告知义务

Article 9 · DMS 生物特征数据风险（EDPB Guidelines 3/2019）

DMS 使用场景	是否触发 Article 9
检测驾驶员闭眼 / 打哈欠（行为判断）	✗ 否 — 行为状态判断
注意力分散检测（眼动 / 头部偏转）	✗ 否 — 行为状态判断
面部识别登录系统（身份验证）	✓ 是 — 唯一识别驾驶员
建立驾驶员面部档案、跨班次追踪	✓ 是 — 生物特征处理

- ❗

若触发Article 9，

- 须同时满足 Article 6合法依据 + Article 9（双重门槛）
 - 强制进行DPIA（Article 35）**
 - 须实施更严格的安全措施

建议：系统支持根据客户的数据保护要求配置是否上传、是否保存、是否打码及访问权限。

Article 13 · 车内告知义务（CJEU C-422/24 裁定确认）

⚠

2025 年 12 月 CJEU Stockholm 公交案裁定：车载摄像头须在采集时即时告知乘客，不得事后通知

车内告知标识必须包含：

- 数据控制者名称和联系方式（运营商）
- 数据保护官（DPO）联系方式（若有）
- 处理目的和法律依据
- 合法利益的具体内容（若采用 Article 6(f)）
- 数据保存期限
- 数据主体的各项权利（访问、删除、反对等）
- 向监管机构投诉的权利

✓

锐明行动：
为欧洲客户提供多语言（英 / 法 / 德 / 荷兰语）车内告知标识模板，配套隐私政策模板 → 销售差异化竞争点

DPA 合同义务 · 跨境数据传输

Article 28 · DPA 数据处理协议（必须签署，无 DPA 即为直接违规）

#	DPA 必须包含	对锐明的含义
1	仅按控制者书面指令处理	云平台不得超出运营商授权范围
2	员工保密义务	访问欧洲数据的员工须签保密协议
3	实施 Article 32 安全措施	加密、访问控制、泄露应对
4	次级处理者须获批准	云服务商须列入 DPA 并获运营商同意
5	协助数据主体权利履行	提供视频检索 / 删除接口
6	合同终止后删除 / 返还数据	客户流失时须彻底清除数据

Article 44–49 · 跨境数据传输（中国企业核心挑战）

✖

欧洲公交数据传输至中国（总部、研发团队访问）即触发跨境传输规则。中国没有欧盟充分性决定，必须使用标准合同条款（SCC）+ 传输影响评估（TIA）。

TIA 须评估的关键内容：

- 评估中国法律（数据安全法 / 网络安全法 / 国家情报法）对数据保护的影响
- 识别中国政府潜在的数据访问权限并评估风险
- 制定技术补充措施（加密、访问控制、数据本地化等）

推荐架构（最稳健方案）：



✔

最佳实践：欧洲数据本地化
欧洲个人数据仅在欧洲处理和存储，中国总部只能获取匿名化聚合数据，从根本上降低跨境传输合规风险。

安全技术措施 · 数据泄露通报 · DPIA 影响评估

Article 32 · 技术和组织措施（TOMs）

安全措施	具体要求
加密	传输 TLS 1.3；存储加密（欧洲数据中心）
访问控制	RBAC 角色权限；客户数据相互隔离；员工按需访问
可恢复性	数据备份；灾难恢复计划
定期测试	渗透测试；安全审计；漏洞扫描
泄露响应	SIEM 日志监控；应急响应流程

Article 33/34 · 数据泄露通报流程



立即发现

锐明内部检测到数据泄露，立即启动应急响应



24 小时内

锐明（处理者）通知运营商（控制者）



72 小时内

运营商向监管机构（SA）报告



高风险时

直接通知受影响乘客（Article 34）



须建立：内部泄露检测分类流程 + 标准化通知运营商模板 + 所有事件记录

Article 35 · 数据保护影响评估（DPIA）

以下场景强制在处理开始前进行 DPIA：

场景	强制依据
ANPR 自动车牌识别	大规模处理可识别个人数据
DMS 若涉及生物特征处理	Art.35(3)(b)；大规模特殊类别数据



差异化竞争优势：

- 提供 DPIA 模板帮助运营商快速完成评估
- 提供 GDPR 合规白皮书减少采购顾虑
- 主动提供数据处理透明度文件

GDPR 下一步合规计划 · 公司体系 + 产品侧输出

公司体系建设

ISO 27001 信息安全管理体系认证	ISO 27701 在 EU 内指定授权代表 · 任命数据保护官（DPO）· 建立 ROPA（Article 30）
-------------------------	---

产品侧合规输出清单（按优先级）

- 立即（0-3 个月）
 - 标准化 GDPR DPA 英文模板 — 法务侧
 - 欧洲多语言车内告知标识模板 — 客户侧
 - 合法利益评估（LIA）文档/ROPA文档 —产品侧、研发侧
 - 产品数据处理白皮书（数据类型 / 流向 / 保留期 / 安全措施） — 产品侧、研发侧
- 中期（3-6 个月）
 - 欧洲数据本地化架构方案落地
 - 参考性 DPIA 模板（提供给欧洲客户）
 - 数据泄露通报流程和模板
- 持续
 - 年度安全评估 + 数据保留审查
 - 安全补丁定期发布机制

典型执法案例警示

违规类型	典型案例	罚款金额
未履行车内告知义务 (Art.13)	Stockholm 公交案 2021	SEK 1600 万 ≈ €140 万
未合法跨境传输数据	Meta 爱尔兰案 2023	€12 亿（史上最大）
未签 DPA 与处理者合作	多个实例	最高 €2000 万

- ⊗ ● 显明风险最高领域（优先处理）：
- 跨境传输合规 — 中国总部访问欧洲数据，须立即完成 SCC + TIA
 - 未签署 DPA 直接合作 — 欧洲销售合同须标准化 DPA 前置